Mini SOC sécurisé sous Rocky Linux

1. Contexte et objectif pédagogique

Ce projet simule une **infrastructure d'entreprise réelle** protégée par une **équipe Blue Team**.
Vous travaillez comme une **équipe SOC** chargée de :

- sécuriser les systèmes
- surveiller les activités
- détecter des attaques
- réagir à des incidents

Rocky Linux est utilisé car il est **équivalent RHEL**, donc **très proche de ce qu'on trouve en entreprise**.

2. Architecture générale expliquée

Machines virtuelles (recommandé)

- **VM 1 – Serveur exposé (Web)**
- **VM 2 – SOC / Logs / SIEM**
- **VM 3 – Monitoring & supervision**
  (+ 1 machine attaquante Kali en option)

Schéma logique

Internet / Attaquant

|

[Firewall Rocky]

|

[Serveur Web Rocky]

|

Logs & Alertes

|

[SOC / SIEM Rocky]

|

[Monitoring Rocky]

Pourquoi cette architecture ?

- Le **serveur web** est une cible réaliste
- Le **SOC** centralise les événements
- Le **monitoring** permet d'anticiper les incidents
- La séparation évite le "tout sur une VM" (mauvaise pratique)

3. Organisation du groupe (3 personnes)

Chaque personne a un **rôle précis**, comme en entreprise.
Les rôles **communiquent entre eux**, mais **ne se chevauchent pas**.

RÔLE 1 – Administrateur système & hardening

Mission principale

Rendre les serveurs **difficiles à compromettre**.

Tu travailles **avant les attaques**, en prévention.

Étape 1 – Installation propre de Rocky Linux

- Installation **minimal**
- Pas d'interface graphique
- Partitionnement clair :
  - /
  - /var
  - /home
  - swap

Pourquoi ?
Limiter l'impact si un service est compromis.

Étape 2 – Sécurisation du système

Comptes et accès

- Désactiver login root SSH
- Authentification par **clé SSH uniquement**
- Comptes nominatifs
- Sudo configuré proprement

SSH

- Port non standard
- Timeout
- Tentatives limitées

Firewall

- Firewalld actif
- Ouverture **uniquement** des ports nécessaires
- Zones réseau bien définies

Étape 3 – Hardening avancé

SELinux

- Mode **enforcing**
- Analyse des logs SELinux
- Ajustements si nécessaire

Protection brute force

- Fail2ban sur SSH et Web

Audit

- auditd actif
- Suivi des :
    - connexions
    - commandes sensibles
    - modifications système

Livrables Rôle 1

- Checklist de hardening
- Rapport Lynis
- Justification des choix sécurité
- Diagramme OS sécurisé

RÔLE 2 – SOC / Logs / Détection d'intrusion (Blue Team)

Mission principale

Voir ce qui se passe et **détecter les attaques**.

Tu travailles **pendant les attaques**.

Étape 1 – Centralisation des logs

Sources de logs

- SSH (/var/log/secure)
- Web (Nginx)
- Système
- Auditd
- Firewall

Mise en place

- rsyslog ou Filebeat
- Envoi des logs vers la VM SOC

Pourquoi ?
Un attaquant efface souvent les logs locaux.
La centralisation empêche ça.

Étape 2 – Wazuh (IDS / SIEM)

Composants

- Wazuh Manager (SOC)
- Wazuh Agents (autres VM)
- Interface Web

Fonctions utilisées

- Détection brute force
- Détection scans réseau
- Détection élévation privilèges
- Alertes temps réel

Étape 3 – Règles personnalisées

Exemples :

- +5 tentatives SSH en 1 min
- Connexion root interdite
- Commandes sudo suspectes
- Accès web anormal

C'est **le cœur cybersécurité du projet**.

Livrables Rôle 2

- Liste des logs collectés
- Règles Wazuh personnalisées
- Screenshots alertes
- Analyse d'au moins 3 attaques

RÔLE 3 – Supervision & Incident Response

Mission principale

Assurer la **disponibilité** et **réagir** quand ça dérape.

Tu travailles **après la détection**.

Étape 1 – Supervision

Outils

- Zabbix **ou** Prometheus + Grafana

Éléments surveillés

- CPU / RAM
- Disques
- Services :
  - SSH
  - Nginx
  - Wazuh
- Temps de réponse web

Étape 2 – Détection d'anomalies

Exemples :

- Pic CPU suspect
- Disque qui se remplit vite
- Service qui redémarre seul
- Charge réseau anormale

Étape 3 – Incident Response (IR)

Procédures écrites

- Brute force SSH
- Compromission web
- Scan réseau massif

Actions possibles

- Blocage IP firewall
- Désactivation compte
- Isolation VM
- Redémarrage service

Scripts

- Bash ou Ansible
- Réactions semi-automatiques

Livrables Rôle 3

- Dashboards monitoring
- Playbooks IR
- Scripts de réponse
- Rapport post-incident

4. Attaques à simuler (obligatoire)

À faire **volontairement** pour prouver que ça marche :

- Nmap
- Brute force SSH
- Upload fichier malveillant
- Tentative sudo
- Connexion hors horaires

Chaque attaque doit :

1. Générer un log
2. Déclencher une alerte
3. Avoir une réponse

5. Compétences validées

- Linux entreprise
- Sécurité système
- SOC / Blue Team
- Détection & réponse
- Travail en équipe structuré

6. Niveau et valeur du projet

- Niveau : **intermédiaire solide**
- Très bon projet :
  - BTS SIO
  - Licence
  - Master
  - Portfolio cybersécurité